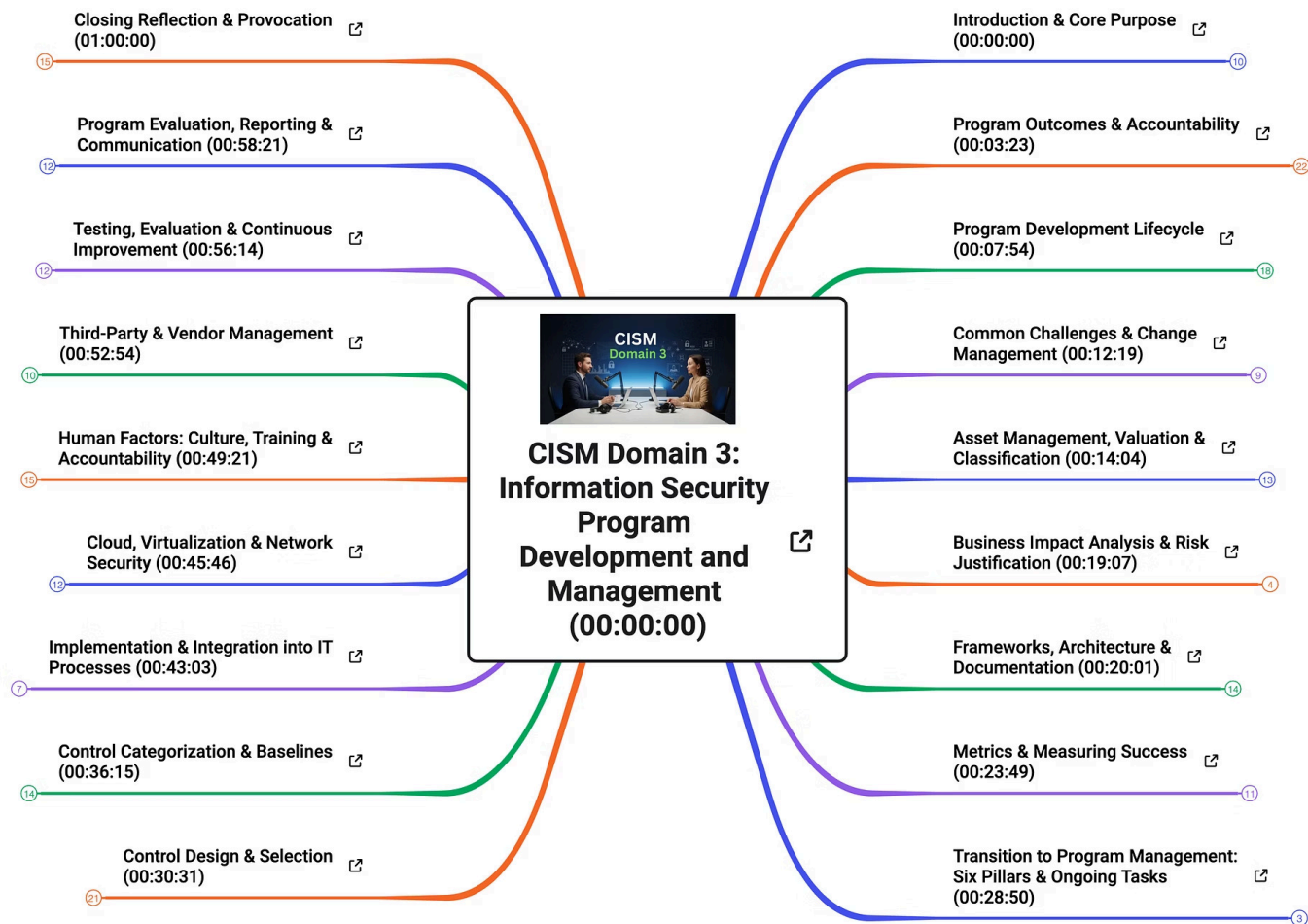




CISM Domain 3: Information Security Program Development and Management

A comprehensive deep-dive into building, structuring, and sustaining an enterprise-grade information security program. This domain covers the full lifecycle — from program inception and governance to asset management, risk justification, frameworks, and continuous improvement.

1	2
Introduction & Core Purpose Program definition, analogy, and leadership mindset	Program Outcomes & Accountability Six essential outcomes and governance bodies
3	4
Development Lifecycle Day-one activities, roadmap, and SDLC integration	Frameworks, Metrics & More Architecture, documentation, and measuring success

Introduction & Core Purpose

MODULE 1 · 00:00:00

Every effective information security program begins with a clear understanding of **what it is, what it does, and why it matters**. This foundational module establishes the conceptual framework that underpins all subsequent domains — grounding abstract security concepts in real-world analogies and leadership principles.

Program Definition & Analogy

An information security program is more than a collection of policies — it is a managed, ongoing organizational capability. Think of it as the operating system that runs all security activities: structured, governed, and continuously updated.

Timestamp: 00:01:56

Fundamental Leadership Mindset

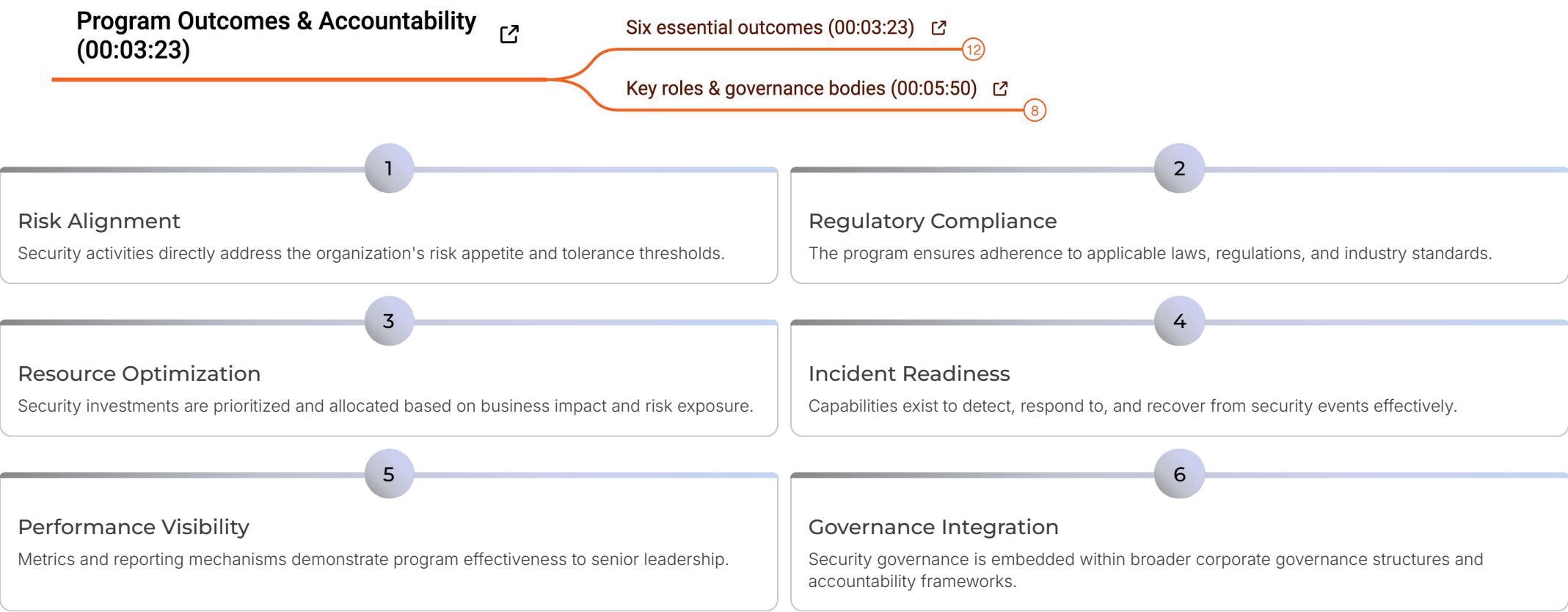
Effective security management demands a shift from purely technical thinking to strategic leadership. The CISM must champion security as a **business enabler**, communicating value to executives, aligning with organizational goals, and cultivating a culture of accountability.

Timestamp: 00:01:19

Program Outcomes & Accountability

MODULE 2 · 00:03:23

A well-designed information security program must deliver measurable outcomes and operate within a clearly defined governance structure. This module identifies the **six essential outcomes** every program must achieve and maps the key roles and governance bodies responsible for program oversight.



Program Development Lifecycle

MODULE 3 · 00:07:54

Building a security program is not a one-time event — it is an iterative lifecycle that begins from day one and evolves as the organization matures. This module walks through the structured phases of program development, from establishing initial authority to embedding security into software development practices.

Program Development Lifecycle (00:07:54)



Day-one activities & authority (00:07:58)

4

Roadmap & planning (00:08:58)

4

SDLC integration & shift-left (00:10:33)

7



Day-One Activities & Authority

Establishing scope, securing executive sponsorship, and asserting the CISM's mandate. Early wins build credibility and create the foundation for program legitimacy. (00:07:58)



Roadmap & Planning

Developing a multi-year strategic roadmap that sequences initiatives by priority, risk reduction impact, and available resources — keeping the program aligned to business objectives. (00:08:58)



SDLC Integration & Shift-Left

Embedding security controls and reviews early in the Software Development Lifecycle — reducing the cost and complexity of remediation by catching vulnerabilities at the source. (00:10:33)

Common Challenges & Change Management

MODULE 4 · 00:12:19

Even well-resourced security programs encounter significant obstacles. Understanding the most common failure modes — and how to navigate them — is essential for any CISM. This module examines the **major constraints that derail programs** and explores proven change management strategies to overcome resistance and drive adoption.

Common Challenges & Change Management (00:12:19)



Major constraints that derail programs (00:12:24)



8

Lack of Executive Buy-In

Without visible sponsorship from senior leadership, security programs struggle to secure funding, enforce policies, and drive organization-wide behavioral change.

Resource & Budget Constraints

Security teams are often expected to do more with less. Prioritizing initiatives based on risk exposure is essential to maximize impact within limited budgets.

Organizational Resistance

Cultural inertia and siloed thinking can block security integration. Effective change management — including communication, training, and stakeholder engagement — is critical for overcoming resistance.

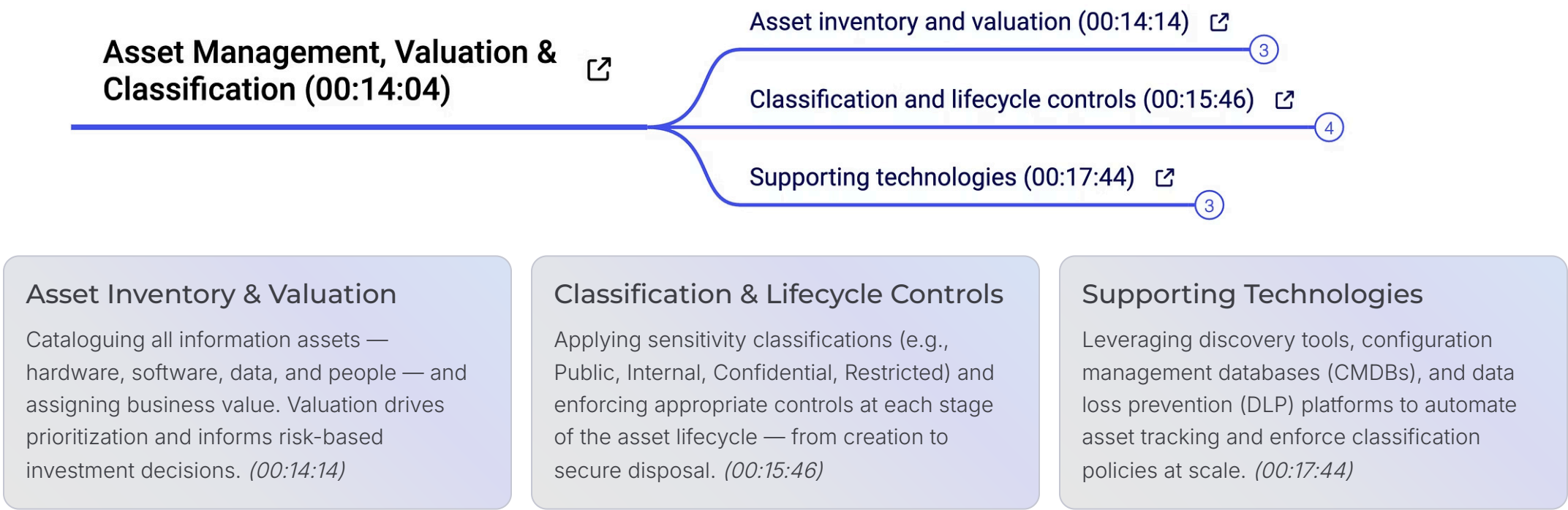
Scope Creep & Complexity

Programs that attempt to address everything simultaneously often lose focus. Clear program boundaries and phased execution help maintain momentum and demonstrate tangible progress.

Asset Management, Valuation & Classification

MODULE 5 · 00:14:04

You cannot protect what you do not know you have. Effective information security programs are built on a **complete and accurate asset inventory** — understanding what assets exist, what they are worth to the organization, and how they should be classified and controlled throughout their lifecycle.



Business Impact Analysis & Risk Justification

MODULE 6 · 00:19:07

Business Impact Analysis & Risk Justification (00:19:07)

BIA process and outputs (00:19:11) 

3

What Is a BIA?

A Business Impact Analysis (BIA) is a structured process for identifying critical business functions, quantifying the potential impact of disruptions, and establishing Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs). It forms the analytical backbone of the security program's risk justification strategy.

BIA Process & Outputs (00:19:11)

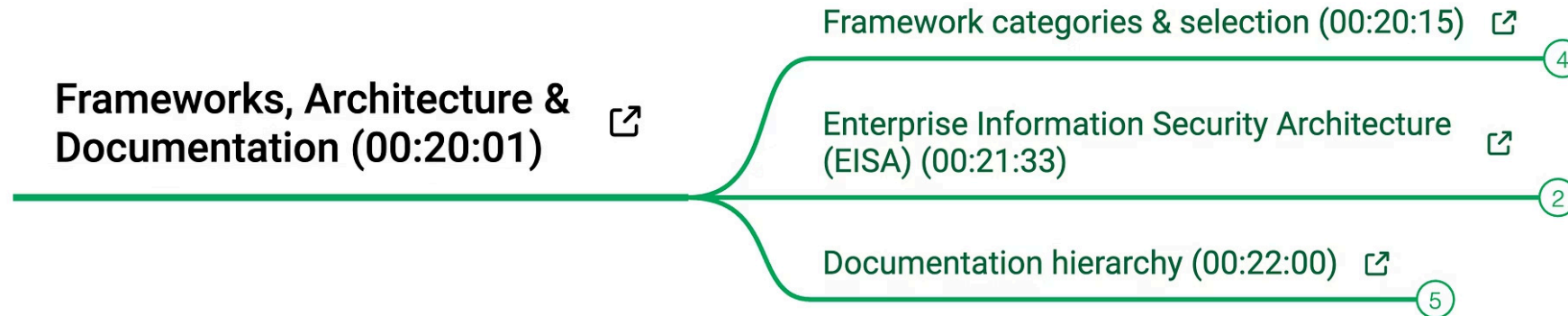
- Identify mission-critical systems and processes
- Quantify financial, operational, and reputational impacts
- Define RTOs and RPOs for each critical asset
- Produce executive-ready risk justification reports
- Align security investments to business continuity priorities

 The BIA is not just a technical exercise — it is the primary tool a CISM uses to translate security risk into business language that resonates with executive stakeholders and board members.

Frameworks, Architecture & Documentation

MODULE 7 · 00:20:01

A mature security program is underpinned by well-chosen frameworks, a coherent security architecture, and disciplined documentation. These elements provide structure, repeatability, and auditability — transforming ad hoc security activities into a systematic, governable discipline.



Framework Categories & Selection

Evaluating and selecting from leading frameworks — NIST CSF, ISO 27001, COBIT — based on organizational size, regulatory environment, and maturity goals. No single framework fits all. (00:20:15)



Enterprise Information Security Architecture (EISA)

EISA aligns security architecture with enterprise architecture, ensuring that security controls are integrated into the organization's technology strategy — not bolted on as an afterthought. (00:21:33)



Documentation Hierarchy

Structuring policies, standards, procedures, and guidelines in a logical hierarchy ensures clarity, enforceability, and ease of maintenance — with policies at the apex and detailed procedures at the base. (00:22:00)

Metrics & Measuring Success

MODULE 8 · 00:23:49

What gets measured gets managed. Security programs that cannot demonstrate effectiveness through **meaningful, reliable metrics** struggle to justify investment and maintain executive confidence. This final module equips the CISM with the tools to build a robust measurement framework aligned to business outcomes.

Metrics & Measuring Success (00:23:49)



Effective metrics criteria (00:24:12)



5

Leading vs lagging indicators (00:25:43)



4

Effective Metrics Criteria (00:24:12)

Good security metrics are **SMART**: Specific, Measurable, Achievable, Relevant, and Time-bound. They must be tied to business objectives, actionable by management, and consistent enough to track trends over time. Avoid vanity metrics that look impressive but drive no decision-making.

Leading vs. Lagging Indicators (00:25:43)

- **Leading indicators** predict future risk — e.g., % of systems patched within SLA, security training completion rates
- **Lagging indicators** reflect past performance — e.g., number of incidents, mean time to detect (MTTD), mean time to respond (MTTR)
- A balanced scorecard uses **both** to provide a complete picture of program health

- ✓ A strong metrics program transforms security from a cost center into a demonstrable value driver — enabling data-driven conversations with the board and continuous program improvement.